



Government
Digital Service



Department for
Science, Innovation
& Technology

Aligning an AWS backup and restore strategy with Secure by Design

October 2025

Contents

Background	3
Purpose	3
Secure by Design on the UK Government Security website	4
Aligning a backup and restore strategy with Secure by Design	5
1. Design approach and best practices	5
2. Governance and accountability	5
3. AWS Backup architecture overview	6
4. Risk assessment and data classification	6
5. Backup frequency and retention policies	7
6. Encryption and key management	8
7. Data replication and geographic resilience	8
8. Testing and validating backup and restore processes	9
9. Automation and orchestration	9
10. Monitoring, logging and alerting	10
11. Incident response and recovery	11
12. Compliance, audit and reporting	11
More information	12

Background

An AWS backup and restore strategy is designed to:

- protect data
- ensure business continuity
- enable effective disaster recovery

It does this by securely backing up critical AWS resources.

By using [AWS Backup](#), government organisations can automate the backup of services such as:

- [Amazon DynamoDB](#)
- [Amazon EC2](#)
- [Amazon Elastic Block Store \(EBS\)](#)
- [Amazon Elastic File System \(EFS\)](#)
- [Amazon Redshift](#)
- [Amazon Relational Database Service \(RDS\)](#)

This can be done while storing copies in storage services like [Amazon S3](#) or [Amazon S3 Glacier](#). By applying encryption and retention policies, the strategy supports compliance and data security. If there's data loss or failure, you can quickly restore backups to the original AWS Region or an alternative one, minimising downtime and maintaining operational resilience.

The [Secure by Design](#) approach is a government framework which embeds cyber security into digital services from the outset. Its goal is to make security an integral, proactive part of all government digital systems, rather than an afterthought.

Purpose

This AWS backup and restore strategy aims to show government organisations how they can align with the Secure by Design approach by integrating data protection into a project's technical and operational controls.

This strategy can be used with all AWS-hosted environments managed by government organisations, including:

- development
- test
- pre-production
- production
- disaster recovery

It includes both structured and unstructured data assets, and covers data residing in or processed by the AWS services.

Its primary objectives are to ensure the availability, integrity and confidentiality of data through consistent backup and restore operations.

Secure by Design on the UK Government Security website

- [Secure by Design policy](#)
- [Implementing Secure by Design](#)
- [Guide to adopting Secure by Design](#)

Aligning a backup and restore strategy with Secure by Design

1. Design approach and best practices

This backup strategy's design approach is based on the [AWS Well-Architected](#) framework and [Top 10 security best practices for securing backups in AWS](#). These include:

- auditability
- automation
- continuous improvement
- encryption
- redundancy

You can automate backups through [AWS Backup](#) policies. This removes manual dependencies and provides consistency. All backups must be encrypted using [AWS Key Management Service \(KMS\)](#), so that data is protected in transit and at rest. Redundancy across multiple Availability Zones (AZs) and regions guarantees resilience against any localised disruptions.

You can use monitoring tools such as [AWS CloudTrail](#), [AWS Config](#) and [AWS Backup Audit Manager](#) to show compliance and detect deviations from policy. These controls keep the framework proactive rather than reactive.

The design approach supports the following Secure by Design principles:

- 3. Adopt a risk-driven approach - by prioritising encryption and automation, you're making sure safeguards are applied where they're most needed
- 4. Design usable security controls - through practical automation
- 6. Design flexible architectures - through continuous refinement
- 8. Defend in depth - by applying layered protection mechanisms
- 9. Embed continuous assurance - because enforcing automated policies improves resilience and shows you're complying with regulatory and internal standards

2. Governance and accountability

Effective governance keeps your backup environment controlled and compliant. Governance structures make sure that operational and security functions are distinct from each other, which reduces insider risk. Each team should document its responsibilities, procedures and evidence in the Information Security Management System (ISMS), so everything's traceable and transparent. Your ISMS may be based on ISO27001 or other similar frameworks and you should have the appropriate policies for backup and restore.

This approach supports the following Secure by Design principles:

- 1. Create responsibility for cyber security risk - by assigning defined accountability
- 7. Minimise the attack surface - by separating duties

- 9. Continuous assurance - through governance reviews
- 10. Make changes securely - with change management procedures requiring all policy adjustments to be validated before they're deployed

You can strengthen governance processes with regular audit reviews and cross-team workshops that confirm you're aligned with your organisation's risk appetite. This collaborative model strengthens the resilience of your organisation through consistent oversight and informed decision-making.

By embedding structured review cycles, you'll be making sure that governance evolves to address emerging threats and meeting Secure by Design principle 3, Adopt a risk-driven approach.

3. AWS Backup architecture overview

The architecture of AWS Backup is at the core of the organisation's data protection strategy. It uses:

- centralised policy management
- Amazon S3 or S3 Glacier for durable data storage
- AWS KMS for encryption key governance
- [AWS Organizations](#) for multi-account policy enforcement

All backups are encrypted, versioned and stored in separate accounts with least-privilege Identity and Access Management (IAM) roles controlling access. You can replicate these across regions so there's continuity in the case of a regional failure. Meanwhile, [AWS Backup Vault Lock](#) makes sure archived data cannot be changed or removed, which protects it from accidental or malicious deletion.

This architecture supports the following Secure by Design principles:

- 6. Design flexible architectures - through modular and adaptive design
- 8. Defend in depth - through layered security
- 9. Embed continuous assurance - through automation and logging

It's helpful to integrate compliance and monitoring capabilities that are native to AWS, like AWS Backup Audit Manager and [Amazon CloudWatch alarms](#). This is because the architecture makes data protection workflows fully visible.

This continuous validation process provides assurance. It puts into practice principle 5, Build in detect and respond security, so that data remains protected from the moment it's created to when it's deleted.

4. Risk assessment and data classification

A structured risk assessment process should underpin all backup operations. Risk assessment considers factors such as:

- threat exposure

- compliance impact
- how critical the service is

Every dataset stored or processed within AWS is assessed and categorised according to its sensitivity, using tagging. This assessment then informs the:

- frequency of backups
- encryption standard
- retention period
- recovery priority

Services such as [AWS Security Hub](#), [AWS Config](#) and [Amazon GuardDuty](#) contribute to risk monitoring by detecting deviations or vulnerabilities. Identified risks should be documented within the ISMS and reviewed during quarterly governance cycles. By default, S3 has no anti-malware capabilities, but when used with GuardDuty, the data is checked for malware.

This structured approach supports the following Secure by Design principles:

- 3. Adopt a risk-driven approach - by linking protection measures directly to risk levels
- 9. Embed continuous assurance - through iterative reviews

Automated tagging in AWS Organizations guarantees classification is consistent across all accounts, while integrated compliance highlights anomalies in real time. This process of continuous reassessment keeps data protection strong throughout its life cycle, supporting principle 5, Build in detect and respond security.

5. Backup frequency and retention policies

How often backups take place should be defined by how critical the data is to the organisation and how volatile the data is. Business-critical systems (for example, financial, customer and operational platforms) should be backed up at least every 4 hours, while less sensitive datasets should follow daily or weekly cycles. You should structure retention policies to enhance data resilience by using Amazon S3 life cycle rules and Amazon S3 Glacier vaults for long-term preservation. Also, it comes with a cost benefit when compared to S3.

Retention periods can vary between short-term operational restores and multi-year archival requirements, as defined in your organisation's data retention policy. You should use the government's [Records management and retention and disposal policy](#) as guidance when defining the organisational data retention policy.

You can use [backup plans](#) in AWS Backup to consistently enforce schedules, which reduces operational errors and means you do not have to rely on manual intervention.

This structured policy design aligns with the following Secure by Design principles:

- 6. Design flexible architectures - by supporting scalable adjustment to workload changes

- 9. Continuous assurance - by defining clear rules
- 10. Make changes securely - which happens following the Secure by Design activity [Evaluating the security impact of changes](#)

AWS Backup Audit Manager reports continuously validate retention rules, which makes them compliant and audit-ready. This also means that life cycle transitions and deletion actions meet policy thresholds.

There's version control for all policy templates in the configuration repository, which makes everything traceable and aligns with principle 2, Source secure technology products.

6. Encryption and key management

All data protected as part of this strategy is encrypted both in transit and at rest. If the organisation uses AWS KMS to create and manage customer-managed keys (CMKs), you'll have control over key rotation, access policies and audit trails. Backup vaults can be encrypted using these CMKs and key usage tightly governed through least-privilege IAM roles.

Encryption configurations are embedded within Infrastructure-as-Code (IaC) templates, which guarantees consistent deployment across accounts and environments. Audit logs from AWS CloudTrail and AWS Config rules make compliance ongoing and detect misconfigurations or unauthorised key use.

This aligns with the following Secure by Design principles:

- 1. Create responsibility for cyber security risk - through the centralised management model
- 7. Minimise the attack surface - by enforcing encryption throughout the data life cycle
- 9. Embed continuous assurance - through continuous monitoring

To further enhance resilience, CMKs are integrated with:

- automated rotation schedules
- dual-control approval workflows

This means that no single operator can change encryption parameters on their own.

Layered governance makes sure cryptographic safeguards evolve securely while preserving operational integrity and auditability. This aligns with the following Secure by Design principles:

- 8. Defend in depth
- 10. Make changes securely

7. Data replication and geographic resilience

You can make systems resilient across UK locations in AWS Backup through cross-Region replication and multi-Availability Zone (AZ) deployments. Critical backups are replicated

automatically to secondary AWS Regions using cross-Region copy. This means you can retrieve backups even in the event of regional service disruption.

This replication strategy is based on recovery time objectives (RTOs) and recovery point objectives (RPOs). Risk assessment defines these objectives. Each replication task uses encrypted channels and keeps metadata consistent across target vaults. You can carry out periodic integrity checks to check the accuracy and completeness of any datasets you've replicated.

This approach reflects the following Secure by Design principles:

- 6. Design flexible architectures - by using AWS's distributed model
- 8. Defend in depth - through redundancy

The use of encryption and regional separation enforces the following principles:

- 3. Adopt a risk-driven approach - by basing controls on risk assessments
- 5. Build in detect and respond security

8. Testing and validating backup and restore processes

Testing is crucial to this strategy, because it confirms that backup and recovery processes will operate effectively. Scheduled restore tests should take place quarterly using isolated AWS accounts so production systems are not disrupted. These tests measure restoration accuracy, integrity and performance against defined RTOs and RPOs.

RTO (Recovery Time Objective) refers to how long a system or service can be unavailable before it causes a significant impact. RPO (Recovery Point Objective) describes how much data loss is acceptable, based on the time between the last backup and a disruption. In simple terms, RTO focuses on how fast you must recover, while RPO focuses on how much data you can afford to lose. These values should be included in the organisation's backup and recovery policy.

Automated test scripts simulate the restoration of sample datasets. This lets you verify encryption, IAM permissions and network configurations. Results should be documented within the ISMS and you can address any variances through corrective actions and configuration updates.

This process aligns with the following Secure by Design principles:

- 4. Usable security controls - by keeping the test procedures practical and repeatable
- 9. Embed continuous assurance - by establishing a repeatable validation cycle
- 10. Make changes securely - by testing all changes before moving to production

Disaster recovery drills and scenario-based simulations evaluate human and procedural readiness, not just technical performance. If, as an organisation, you combine operational drills with automated validation, you can be more confident that your AWS Backup systems will perform reliably during real incidents.

9. Automation and orchestration

Automation is key to the consistency, reliability and scalability of an organisation's AWS backup environment. You should set up AWS backup plans to automatically detect new resources and apply the appropriate policy based on existing tags. This means that new resources receive immediate protection without requiring manual configuration.

Infrastructure-as-Code (IaC) tools such as [AWS CloudFormation](#) and [Terraform](#) define backup resources declaratively, reducing drift and human error.

Orchestration extends automation across the backup life cycle, triggering notifications through [Amazon EventBridge](#) and [AWS Lambda](#) for policy compliance, validation and alerting. These integrations reduce dependency on manual intervention and enhance response times in the event of anomalies.

This design aligns with the following Secure by Design principles:

- 4. Design usable security controls - by embedding simple, repeatable automation
- 6. Design flexible architectures - through modular code-driven processes
- 9. Embed continuous assurance - by enabling persistent compliance checks through event-based workflows

By integrating automation with continuous delivery pipelines, every deployment is subject to backup policy validation before release. This means that resilience is built in from the start.

10. Monitoring, logging and alerting

Continuous monitoring provides transparency and helps detect deviations from backup policy early on.

You can use AWS CloudWatch, AWS Config and AWS Backup Audit Manager to track the health, success rate and latency of backup operations. Logs from AWS CloudTrail record all backup and restore activity, while [Amazon SNS](#) provides real-time notifications for success, failure or policy violations.

These monitoring mechanisms allow you to rapidly escalate incidents. With the help of dashboards that summarise key metrics like backup coverage percentage and restore test success rates, you can use data to improve recovery processes.

The monitoring ecosystem also makes defence proactive, because it links alerts with AWS Security Hub and Amazon GuardDuty. This allows you to correlate backup anomalies with broader security events.

Continuous reporting and root-cause analysis contribute directly to operational learning, allowing the organisation to refine its controls over time.

Monitoring and alerting reinforce the following Secure by Design principles:

- 5. Build in detect and respond security - by integrating immutable logging, so that audit trails are tamper-proof

- 8. Defend in depth - through layered oversight, so that issues affecting backups are investigated as part of a wider security context
- 9. Embed continuous assurance - by providing constant visibility into operational health

11. Incident response and recovery

Incident response for backup and recovery follows a structured process integrated into the organisation's cyber security incident response plan (CSIRP). Good coordination between IT operations, security and compliance teams allows the organisation to meet business continuity objectives even during adverse events.

After the detection of an incident, for example, data corruption, unauthorised access or failed restoration, the following should happen:

- incident handlers are immediately notified through AWS SNS and ServiceNow workflows
- investigations prioritise rapid containment and restoration from the most recent valid backup
- all recovery activities are logged, timestamped and subject to post-incident review
- lessons learned are incorporated into configuration baselines to prevent them happening again

This structured response model supports the following Secure by Design principles:

- 9. Embed continuous assurance - by ensuring detection and response to issues in production systems
- 10. Make changes securely - through controlled restoration procedures

To enhance resilience, organisations should conduct simulated cyber-recovery exercises which test both technical and procedural readiness. These drills evaluate backup immutability, cross-region restoration and response-team coordination under realistic conditions.

Being continually prepared means every incident, real or simulated, strengthens organisational capability and confidence. This supports the following principles:

- 3. Adopt a risk-driven approach
- 9. Embed continuous assurance

12. Compliance, audit and reporting

Compliance with statutory, regulatory and contractual requirements should be central to the backup strategy. Regular internal audits should assess alignment with the [Data Protection Act 2018](#), [UK GDPR](#) and the organisation's internal data-governance

standards. You can use AWS Backup Audit Manager and [AWS Config conformance packs](#) to automate evidence collection and generate reports quarterly for management and auditors.

You should track audit findings through corrective-action registers and monitor them until they're resolved by the internal audit team. You should review all backup configurations and retention policies annually or following any significant architectural changes by the IT manager or equivalent. These reviews keep controls effective and proportionate to business risk.

This supports the following Secure by Design principles:

- 1. Create responsibility for cyber security risk - by assigning clear ownership for compliance management
- 2. Source secure technology products - through reliance on AWS-certified compliance tools
- 9. Embed continuous assurance - by formalising the verification process

More information

- [Secure by Design Principles \(UK Government Security\)](#)
- [Secure by Design Activities \(UK Government Security\)](#)
- [Data Protection Act 2018 \(Legislation.gov.uk\)](#)
- [The cloud security principles \(NCSC\)](#)